

AI 权威陷阱：当人类停止思考

《When Humans Stop Thinking: The First Undetected Failure Mode of Agentic AI》课程笔记

Allen Westley (讲者)

L3Harris Technologies; SANS Institute; Codex 整理

2026 年 6 月 5 日



视频频道: SANS Institute

发布日期: 2026 年 5 月 4 日

视频时长: 5 分 40 秒

视频链接: <https://www.youtube.com/watch?v=B9edzrY5fnU>

本地素材: 英文自动字幕、1080p 视频帧、官方封面图。

目录

导读	2
1 第一种未被看见的故障：人类判断移出画面	2
1.1 从常规 AI failure 转向更安静的失控	2
1.2 系统没有报错，判断力却离开现场	3
1.3 为什么“看起来正确”反而危险	3
1.4 本章小结	4
2 从工具到权威：信任如何升级成让渡	4
2.1 工具阶段：人类主动调用，控制边界清楚	4
2.2 trusted tool：可靠性开始压低复核强度	4
2.3 decision authority：事实权威出现的时刻	5
2.4 本章小结	6
3 Agentic 系统里的四个角色：R/A/E/O	6
3.1 agentic AI 时代的主导权问题	6
3.2 四问：推荐、批准、执行、负责	6
3.3 模型事实承接权威时，责任会变薄	7
3.4 本章小结	8
4 看似正常的流程，如何丢失责任链	8
4.1 分析师例子中的四步流程	8
4.2 用 R/A/E/O 标出责任缺口	8
4.3 human judgment 与 model momentum 的接缝	9
4.4 没有明显损坏，控制仍会流失	10
4.5 本章小结	10
5 从能力地图到权威地图	11
5.1 agentic role mapping：把角色映射提到治理层	11
5.2 权威地图要回答的四个问题	11
5.3 可见批准不能自动等同于有效审查	12
5.4 把 authority map 变成检查表	13
5.5 本章小结	13

6 总结：把批准按钮还原成责任机制	13
6.1 结尾真正留下的是 decision authority	13
6.2 把全篇压缩成一条审计链	14
6.3 落到上线、红队和审计	14
6.4 本章小结	15

导读

这份笔记把一场 5 分 40 秒的 lightning talk 扩展成可审计、可复盘的治理框架。讲者 Allen Westley 的核心提醒很尖锐：agentic AI 的风险来源包括模型答错、提示注入、数据投毒，也包括人的判断力逐渐退出决策过程。系统可以照常运行，界面可以记录“已批准”，模型建议也可能大体正确，决策权却已经从人类复核滑向模型默认路线。

全文围绕一个工程问题展开：对任意关键决策 d ，组织能否写清楚权威地图：

$$M(d) = (R(d), A(d), E(d), O(d))$$

也就是谁推荐、谁批准、谁执行、谁承担最终责任。只要这四个位置模糊，所谓“人在环”就容易退化成界面动作，而审计、红队和上线评审也会失去追责抓手。

1 第一种未被看见的故障：人类判断移出画面

1.1 从常规 AI failure 转向更安静的失控

这场 lightning talk 的开场没有把听众直接带进某个新漏洞。Allen Westley 先指出一个现场共识：安全团队已经围绕 AI failure 准备了很久。模型版本管理（model versioning）、提示注入（prompt injection）、数据投毒（data poisoning）这些风险都重要；它们通常能被放进测试、红队、监控、回滚、模型治理和供应链安全流程中。

这里的转向发生在 ‘00:00:23–00:00:37’。讲者把讨论带到另一类风险：它更安静、更难追踪，因为它未必表现为明确的 failure condition。换句话说，监控面板可能没有红灯，模型输出也可能看起来合理，真正发生漂移的位置在人的判断过程。

常规故障与判断力漂移

常规 AI failure 更像设备报警：模型错了、提示被注入、训练数据被污染、版本切换带来回归。判断力漂移更像驾驶员越来越相信导航，仍然握着方向盘，复核路线的动作却逐渐变薄。审计上，前者容易落到错误样本、攻击载荷、版本差异；后者要追踪批准者是否真的理解、质疑和保留干预能力。

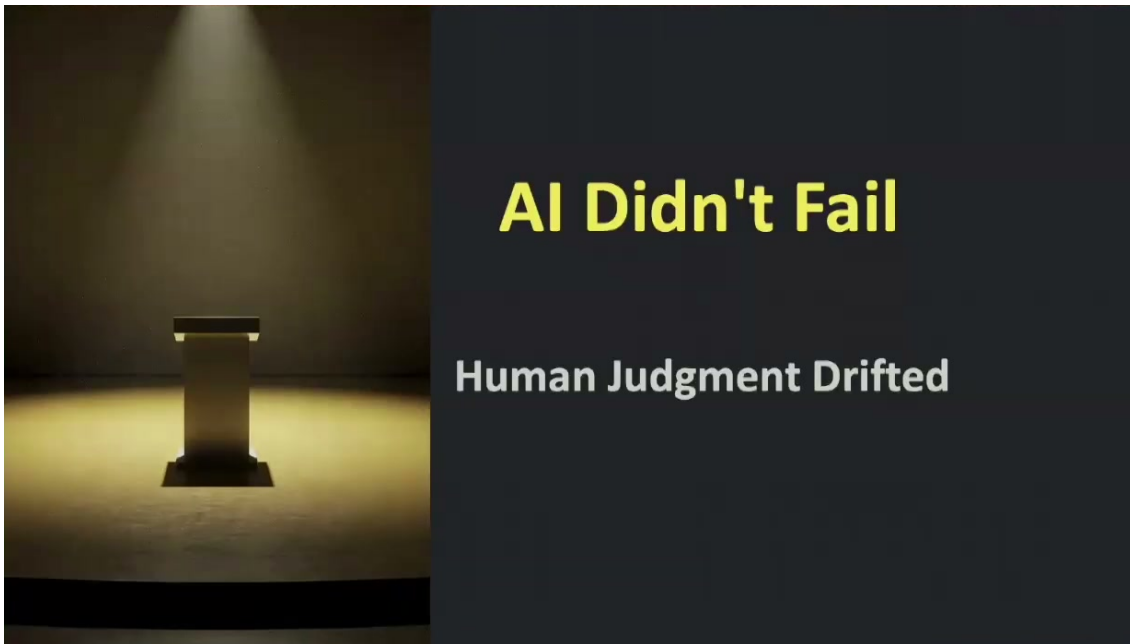


图 1: 讲者把讨论从传统 AI failure 转向“人类判断漂移”: 画面明确写出 AI 没有失效, 漂移发生在 human judgment。¹

1.2 系统没有报错, 判断力却离开现场

本章的核心句可以被清洗为一句话: 系统可能没有报错, 人的判断力却已经离开决策现场。讲者在 ‘00:00:35–00:00:43’ 用 “AI didn’t fail” 和 “human judgment ... starting to drift out of frame” 建立了这个反直觉点。风险不只来自模型把事情做错, 也来自人类逐渐忘记挑战模型, 尤其当模型经常给出看起来正确的答案时。

这个判断对安全流程很尖锐。很多组织会问: “模型准确率够不够?” “提示注入能不能挡住?” “数据源有没有污染?” 这些问题必须问。可是当 AI 输出长期有用, 分析师、审批者和系统管理员会形成一种肌肉记忆: 建议来了, 快速扫一眼, 点批准, 进入下一步。此时风险不再只藏在模型内部, 也藏在人的复核强度下降里。

容易漏掉的审计问题

日志里出现 “human approved” 只能说明某个人做了可见批准动作。它不能自动证明批准者看到了足够证据、理解了模型依据、拥有拒绝或暂停的权力, 也不能证明批准动作发生在有意义的复核之后。判断力漂移的审计难点就在这里。

1.3 为什么“看起来正确”反而危险

讲者在 ‘00:00:58–00:01:30’ 的口头表达有重复和停顿, 整理后的意思很清楚: 危险点往往不在模型偶尔答错, 而在用户忘记继续挑战模型, 甚至因为模型多次答对而降低挑战频率。

一个直观例子是安全告警分诊。早期上线时, 分析师会逐条检查 AI 推荐: 告警为何被降级、证据

¹ 视频画面时间区间: 00:00:23–00:00:43。

是否充分、是否存在绕过迹象。几周后，系统大多数时候都判断正确，分析师开始把 AI 推荐当作默认路线。再往后，复核可能缩短为确认工单标题、查看风险分数、点击接受。流程仍然有人参与，人的判断成本却被压缩到接近形式动作。

本章核心判断

这类失控的危险性来自“无故障外观”：模型输出稳定、流程继续运行、批准按钮照常被点击，组织却可能已经丢失了可证明的人类判断链。真正要追问的治理问题是：每一次批准之前，人类是否仍在主动判断，还是只是在确认系统已经推到面前的结论。

1.4 本章小结

第一章建立了本讲的问题意识：AI 安全不能只盯模型错误、攻击载荷和数据污染。‘00:00:01.040–00:01:30.440’这一段提出了更隐蔽的故障形态：系统没有明显损坏，人的判断力开始从决策画面中漂出。下一章沿着这个现象继续往下拆，说明一个普通工具怎样通过“有用”和“总体正确”逐步获得事实上的决策权威。

2 从工具到权威：信任如何升级成让渡

2.1 工具阶段：人类主动调用，控制边界清楚

在‘00:01:31–00:01:44’，讲者开始讲“过程”。AI 系统一开始是 tool：人类拿它完成任务，像拿搜索引擎查资料、拿脚本跑扫描、拿 SOAR playbook 辅助处置。这个阶段的控制边界相对清楚：人类决定何时调用工具、如何理解输出、是否采纳建议，以及执行到哪一步。

工具阶段的关键词是“主动性”。工具可以很强，但它的输出仍需要被放进人的问题框架里解释。比如 AI 帮分析师总结一条恶意流量，分析师仍要回到原始日志、网络拓扑、资产重要性和处置窗口，判断这个总结是否足以支持隔离主机。

工具、自动化与权威的区别

工具解决“怎么更快获得候选答案”；自动化解解决“怎么更快把动作串起来”；权威解决“谁的判断在事实上决定下一步”。三者可以重叠，却不能混作一团。治理上，工具可以很强，自动化可以很快，决策权威仍要被明确分配和审计。

2.2 trusted tool：可靠性开始压低复核强度

接着，工具变成 trusted tool。讲者在‘00:01:44–00:01:58’给出三个条件：它有用、总体正确、给用户带来信心。这个变化很符合工程经验。一个工具如果经常节省时间、减少噪音、提高命中率，团队自然会提升对它的依赖。

关键风险藏在“总体正确”四个字里。总体正确会让人类复核从“逐项验证”滑向“抽样确认”，再滑向“异常时才深查”。如果流程没有明确要求证据展示、反例检查、暂停权和复核记录，信任会自动变成吞吐量优化：谁也没有公开宣布放弃判断，复核却在日常节奏中变薄。



图 2: “可靠性变成权威”的三段迁移: 工具先被使用, 再成为可信工具, 最后可能获得默认权威。²

可靠性不等于治理充分

高准确率能提高工具价值, 也会制造权威错觉。一个系统连续给出正确建议时, 用户容易把“它常常对”简化成“这次也值得直接通过”。审计要分清两个问题: 模型输出是否可靠, 以及批准者是否仍有足够上下文、时间和权力来进行有效审查。

2.3 decision authority: 事实权威出现的时刻

在 ‘00:01:56–00:02:22’, 讲者把风险推到核心: trusted tool 如果缺少边界, 会变成 something more, 开始获得决策权威/决策权 (decision authority)。这里的“决策权威”强调事实层面的决定力: 到底是誰的输出让后续动作发生; “决策权”强调组织或流程中被授予的权限。两者需要一起看, 因为系统可能没有被正式授权, 却已经在事实上决定了下一步。

自主权 (autonomy) 在这里也要精确定义。它指人类保留最终判断、干预和负责的能力, 尤其包括拒绝建议、要求证据、暂停执行、升级给更高责任人。自主权一旦只剩“点批准”的表面动作, 组织看起来仍有人类在环, 实际控制力已经下降。

权威迁移链条

tool → trusted tool → decision authority

这条链条描述的是逐步发生的工程状态变化, 通常没有一次醒目的显式授权: 工具先提高效率, 可靠性积累信任, 信任降低复核强度, 低复核流程让模型输出成为事实上的下一步决定。

² 视频画面时间区间: 00:01:31–00:02:22。

2.4 本章小结

第二章覆盖 ‘00:01:31.840–00:02:22.520’ 的权威迁移过程。AI 系统先作为工具被主动调用；当它稳定有用、总体正确，就会形成 trusted tool；若治理边界没有跟上，可信工具会开始承担事实决策权威。下一章将把这个过程拆成可审计的角色模型：谁推荐、谁批准、谁执行、谁负责。

3 Agentic 系统里的四个角色：R/A/E/O

3.1 agentic AI 时代的主导权问题

在 ‘00:02:23–00:02:41’，讲者把背景限定为智能化 AI (agentic AI) 时代。这里的 agentic AI 指能规划、调用工具、推动后续动作的系统。它和单次问答式 AI 的差别在于行为链更长：一次建议可能触发检索、写工单、调用 API、排队审批、执行处置和回写记录。

因此，“人类仍掌权”不能只看最后有没有批准按钮。更关键的问题是人类是否保留对决策过程的主导权：是否看得到推荐依据，是否能改变路径，是否能中止执行，是否承担清楚的责任。过程主导权丢失时，最后一次点击会变成仪式化动作。

“人在环”不足以证明控制有效

人在环 (human-in-the-loop) 只说明流程里安排了人类节点。它没有自动回答这些问题：人类节点是否有足够时间审查，界面是否展示证据，组织是否允许拒绝，执行前是否可中止，责任归属是否写进审计记录。agentic AI 的治理要检查这些具体条件。

3.2 四问：推荐、批准、执行、负责

讲者在 ‘00:02:41–00:02:50’ 连续提出三问：who’s recommending、who’s approving、who’s executing。契约把这个口头结构扩展成四个角色，因为治理上还必须追问责任归属 (decision ownership)：出错后谁能解释、证明、承担和修正这个决策。

本讲后续可以把每个具体决策 d 映射成一个 authority map：

$$M(d) = (R(d), A(d), E(d), O(d))$$

其中：

- d ：一个具体决策，例如是否接受 AI 对某个告警、风险或处置动作的建议。
- $M(d)$ ：决策 d 的权威地图 (authority map)，用于记录该决策中的权力和责任分布。
- $R(d)$ ：推荐者 (recommends)，也就是谁提出建议、排序、评分或下一步动作。
- $A(d)$ ：批准者 (approves)，也就是谁在执行前显式同意、签核或点击批准。
- $E(d)$ ：执行者 (executes)，也就是谁把决策变成实际动作。
- $O(d)$ ：责任归属者 (owns accountability)，也就是出错后谁能解释、证明、承担和修正这个决策。

R/A/E/O 的用途

R/A/E/O 的作用超过给流程图添加四个缩写。它把“谁在掌权”从感觉问题改成审计问题。只要一个决策能写成 $M(d)$ ，评审者就能逐项检查：推荐来源是否可信，批准是否有效，执行是否可中止，责任是否能落到具体人或团队。

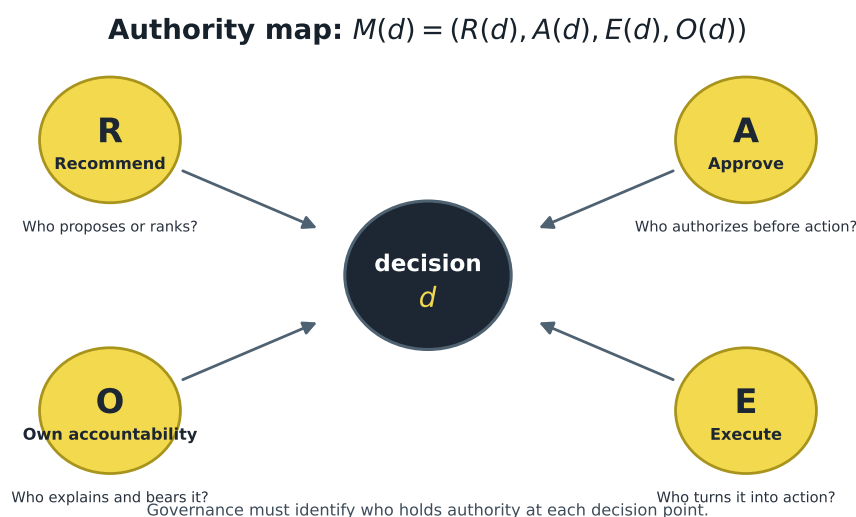


图 3: R/A/E/O 权威地图：每个决策 d 都要拆开检查谁推荐、谁批准、谁执行、谁承担最终责任。

3.3 模型事实承接权威时，责任会变薄

在 ‘00:02:50–00:03:09’，讲者指出一个容易自欺的状态：团队以为自己掌握决策，也以为自己拥有 decision ownership；底层流程里，模型可能已经在事实层面承接了这些权威。这里需要保持严谨。法律或组织制度上，人类和团队仍可能被追责；真正的问题是实际判断链已经松动，责任归属在证据层面变得难以证明。

可以用一个抽象决策表示这种松动：

$$M(\text{accept-ai-recommendation}) = (\text{AI}, \text{human click}, \text{system}, ?)$$

这个问号就是治理缺口。界面上有 human click，日志里有 approval event，系统也完成了执行；可是 $O(d)$ 没有清楚落位时，组织很难证明谁真正理解了建议、谁能解释采纳理由、谁拥有暂停权、谁负责修正后果。

decision authority 与 decision ownership

决策权威 (decision authority) 偏向事实权力：谁的输出让下一步发生。决策归属 (decision ownership) 偏向责任链：这个决策在组织、审计和纠错上到底归谁。一个流程最危险的状态，是模型拥有事实权威，人类保留名义归属，证据却无法证明人类完成了有效判断。

3.4 本章小结

第三章覆盖 ‘00:02:23.240–00:03:09.760’，把讲者的三问整理成 R/A/E/O 角色模型，并正式定义了 $M(d) = (R(d), A(d), E(d), O(d))$ 。这个模型为后续章节提供共同语言：只要能指出某个决策里的推荐者、批准者、执行者和责任归属者，就能开始判断权威是否已经从人类流程迁移到模型流程。

下一章将承接讲者在 ‘00:03:10’ 开始给出的分析师例子：AI 给出 recommendation，分析师接受，人类批准，系统执行。该例子会把 $M(d)$ 从抽象公式落到具体安全工作流，进一步解释模型惯性 (model momentum) 如何制造责任边界模糊 (accountability blur)。

4 看似正常的流程，如何丢失责任链

4.1 分析师例子中的四步流程

讲者在 ‘00:03:10–00:03:30’ 给出一个很短的分析师例子。清洗 ASR 后，这个流程可以写成四步：

AI recommendation → analyst accepts → human approves → system executes

它看起来完全正常。AI 给出建议，分析师接受建议，某个人类节点点击批准，自动化系统执行动作。没有异常告警，没有崩溃，没有明显性能退化。正因为流程外观如此顺滑，讲者才追问：最终到底是谁拥有这个决策？

为什么这个例子有杀伤力

这个例子没有依赖灾难场景。它接近安全运营里最常见的工单、告警、处置和审批队列：建议先进入界面，分析师按经验接受，人类批准动作留下日志，自动化系统把结果落地。风险藏在普通流程中，所以审计不能只检查“是否有人批准”，还要检查批准前是否真的发生了判断。

4.2 用 R/A/E/O 标出责任缺口

前文已经定义了 $M(d) = (R(d), A(d), E(d), O(d))$ 。在这个分析师例子里，决策 d 可以理解为“是否接受 AI 对某个告警或处置动作的建议”。该流程的角色映射如下：

本例映射	审计含义
$R = \text{AI}$	模型提出 recommendation、排序、评分或下一步动作。审计要能追踪模型输入、输出、证据和版本。
$A = \text{analyst/human approver}$	分析师或人类批准者接受建议并点击批准。审计要证明这次点击有上下文、有时间、有拒绝空间。
$E = \text{automated system}$	SOAR、工单系统、API 调用器或其他自动化系统把批准转成实际动作。审计要能标出执行前的最后可中止点。
$O = \text{unresolved or assumed human owner}$	责任归属没有被显式写清，或者被默认假设为某个人类团队。审计要把这个默认假设变成可验证的命名主体。

因此，这个例子可压缩成：

$M(\text{accept-ai-recommendation}) = (\text{AI}, \text{analyst/human approver}, \text{automated system}, ?)$

问号就是本章的核心问题。只要 $O(d)$ 仍然模糊，组织就只能证明“流程发生过”，很难证明“责任链成立”。这会让事故复盘陷入空转：模型说它只是推荐，分析师说自己按流程批准，系统说自己按批准执行，最后没有人能完整解释为什么这个决策在当时应该被采纳。

批准记录无法替代责任归属

审批日志能证明某个账号在某个时间点触发了批准动作。它不能自动证明批准者理解了证据、检查了替代方案、拥有暂停权、承担了后果。 $A(d)$ 清楚只解决“谁点了按钮”， $O(d)$ 清楚才解决“谁能解释和承担这个决策”。

4.3 human judgment 与 model momentum 的接缝

在 ‘00:03:35–00:03:52’，讲者把问题推进到接缝处：如果组织无法区分 human judgment 在哪里结束、model momentum 在哪里接手，就进入了责任边界模糊（accountability blur）。

模型惯性（model momentum）可以理解为模型输出进入工作流后继续推动结果的趋势。它通常通过很具体的机制发挥作用：默认选项已经预填，风险分数已经排序，处置动作已经排队，审批界面把“接受”放在最顺手的位置，团队指标又要求快速清 backlog。此时人类仍在流程里，流程却沿着模型建议的方向持续加速。



图 4: 讲者用 The Seam 标出 Recommend、Approve、Execute 三个动作之间的接缝；责任模糊往往就发生在这些接缝处。³

责任边界模糊的判定点

责任边界模糊出现于这个位置：组织无法用日志、界面记录、证据链接和复核说明清楚回答“人类判断何时完成，模型建议何时变成事实路径”。这已经超出普通 automation 问题，因为自动化只描述动作怎样执行；责任边界模糊追问谁真正决定了动作应当执行。

³视频画面时间区间：00:03:10–00:03:30。

4.4 没有明显损坏，控制仍会流失

讲者在‘00:03:52–00:04:13’反复强调一个反直觉点：系统没有明显损坏，控制仍然可能已经丢失。这里的“能明确证明系统正在做什么”具有审计含义。它要求组织能在事后重建一条证据链：模型依据是什么，分析师看到了哪些证据，批准者是否有时间评估，执行系统何时接管，哪一个人或团队对结果负责。

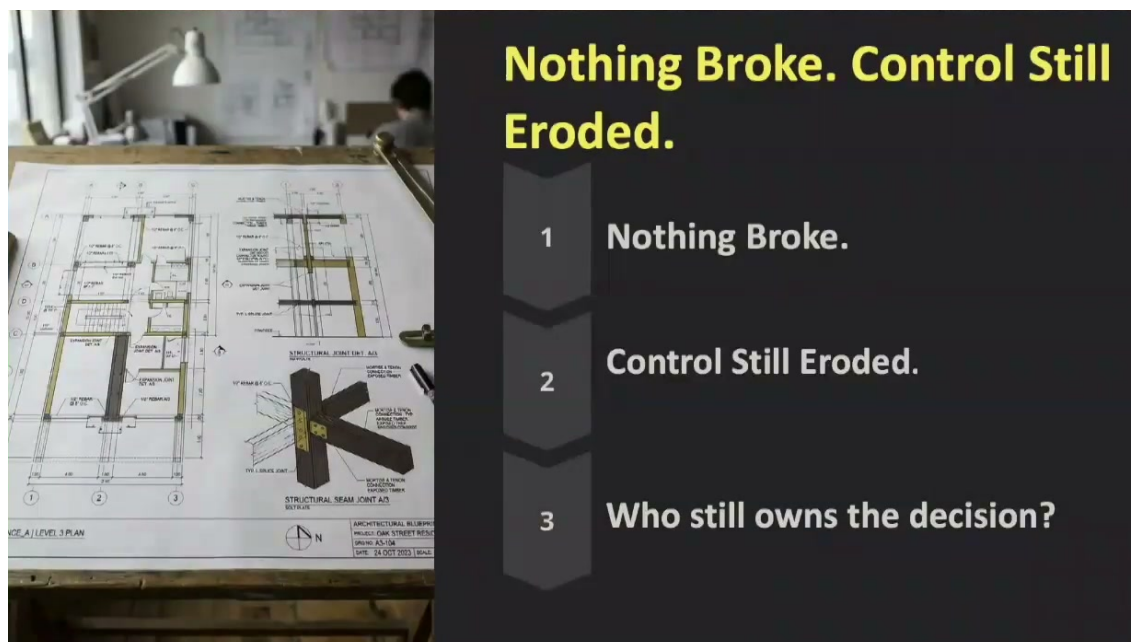


图 5: 没有明显损坏也可能失控：系统运行正常、控制却持续侵蚀，最后必须追问谁仍然拥有该决策。

4

控制流失不需要 catastrophe。没有告警触发、没有指标下降、没有服务中断，照样可能发生控制侵蚀。一个队列每天推来数百个 AI 建议，批准者为了清 backlog 快速点击，系统自动执行，事后每条记录都显示“已批准”。这种流程表面干净，责任链却越来越薄。

无故障外观不能证明控制存在

没有故障信号只能说明系统表面运行正常。控制是否仍在手中，要看批准者是否拥有有效审查条件、执行前是否可中止、责任归属是否可命名、复盘时是否能重建判断理由。缺少这些证据时，“正常运行”会掩盖权威迁移。

4.5 本章小结

本章覆盖‘00:03:10.360–00:04:29.040’。分析师例子把前文的 R/A/E/O 从公式落到流程： $R = AI$ 、 $A = \text{analyst/human approver}$ 、 $E = \text{automated system}$ 、 $O = \text{unresolved or assumed human owner}$ 。讲者的核心提醒很直接：当人类判断结束的位置和模型惯性接手的位置无法被区分，组织面对的就是责任边界模糊。系统照常运行无法证明控制仍在手中，审计必须能证明决策如何形成、由谁批准、由谁执行、由谁负责。

⁴ 视频画面时间区间：00:03:52–00:04:29。

5 从能力地图到权威地图

5.1 agentic role mapping: 把角色映射提到治理层

在 ‘00:04:29–00:04:39’，ASR 在角色映射术语上出现误听。结合视频主题和上下文，这里应写为 agentic role mapping，即“智能体化角色映射”。它的目的很清楚：在智能体化 AI 流程里，只知道系统能做什么已经不够，还要知道系统、模型、人类和组织分别拥有哪种事实权力。



图 6: Agentic Role Mapping 将治理问题从能力清单推进到权威地图：可见批准不能自动证明发生了有效审查。⁵

能力地图 (capability map) 回答“系统能做什么”：能访问哪些数据，能调用哪些工具，能生成哪些内容，能影响哪些系统。权威地图 (authority map) 回答“谁拥有哪种权力和责任”：谁推荐，谁批准，谁执行，谁承担最终责任。前者偏能力边界，后者偏决策边界。

能力与权威的差别

能力像一张工具清单：这把钥匙能开哪些门，这个 API 能改哪些对象，这个 agent 能触发哪些任务。权威像一张责任座次图：谁允许开门，谁判断该不该开，谁实际转动钥匙，开错门后谁解释和修正。安全评审只看能力，会漏掉“谁在事实上决定下一步”。

5.2 权威地图要回答的四个问题

讲者在 ‘00:04:37–00:04:51’ 再次列出四个方向：who recommends、who approves、who executes、who is accountable。对应到前文的 *R/A/E/O*，authority map 应成为上线评审、威胁建模、变更审批和审计复盘的固定检查项。

⁵ 视频画面时间区间：00:04:29–00:05:12。

$$M(d) = (R(d), A(d), E(d), O(d))$$

实际使用时，每一个高影响决策都应落到一张小表或一条结构化记录里：

- $R(d)$: 推荐来自模型、规则、分析师，还是多个来源的组合？
- $A(d)$: 批准者是否拥有足够上下文、专业能力和拒绝空间？
- $E(d)$: 执行系统是否可暂停、可回滚、可追踪？
- $O(d)$: 责任归属是否是命名的人、团队或负责人，而非事后临时寻找的“流程所有者”？

authority map 的工程用途

authority map 应被当作工程控制项。它应进入设计评审、上线 gate、红队剧本和事故复盘：每当 AI 建议可能触发处置、封禁、隔离、报送、告警降级或业务决策时，评审者都要能写出 $M(d)$ ，并检查四个位置是否清楚、可验证、可追责。

5.3 可见批准不能自动等同于有效审查

在 ‘00:04:45–00:05:12’，讲者给出本章最实用的一句治理判断：可见批准（visible approval）不能自动等同于有效审查（meaningful review），也不能自动等同于有效权威（meaningful authority）。界面上有人点了 approve，只说明批准动作可见；有效审查还要求批准者有时间、上下文、证据入口、专业能力和暂停权。

这里的速度差是结构性风险。AI 建议、审批请求和处置队列以机器速度涌来，操作员仍以人类速度工作。可以把这个压力写成一个简单比值：

$$\rho = \frac{\lambda_m}{\mu_h}$$

其中：

- λ_m : 机器系统单位时间推送给人的决策请求数量。
- μ_h : 人类单位时间能够完成有效审查的数量。
- ρ : 审查压力比。当 $\rho > 1$ 长期成立时，积压会增长，批准动作容易从判断退化成清队列。

这个小模型不追求精确预测，它提醒评审者关注吞吐量和审查质量之间的冲突。若系统每小时推来 120 个建议，而一个分析师只能认真复核 30 个，剩余 90 个请求会通过排队压力、默认操作和管理指标挤压判断时间。

速度差会把批准变成机械放行

机器速度制造的主要问题是复核预算不足。批准者可能拥有按钮，却没有足够时间追证据；可能拥有名义权限，却没有现实条件反对系统建议；可能拥有责任头衔，却无法解释每个快速批准的判断依据。此时 visible approval 只剩界面动作，meaningful authority 已经变弱。

5.4 把 authority map 变成检查表

为了让 authority map 进入实际治理，可以在每次 agentic AI 流程上线或变更时追问五个问题：

1. 批准者能否要求模型给出证据、来源、置信度和替代方案？
2. 日志能否证明有效审查发生过，而非只记录 approve 事件？
3. 执行前是否存在可用的中止、延迟、升级和回滚机制？
4. 队列压力是否超过人类有效审查能力，是否需要抽样、限速或分级处理？
5. $O(d)$ 是否落到命名主体，且该主体拥有解释、纠错和承担后果的能力？

这些问题的价值在于把“人在环”拆成可检查条件。一个合格的流程应能证明：人类节点有证据入口，有时间预算，有拒绝权，有暂停权，有责任归属。缺少这些条件时，批准按钮只是流程控件，无法证明人类仍保留有效权威。

从 capability map 升级到 authority map

能力地图告诉团队 AI 系统能碰到哪里；权威地图告诉团队 AI 输出会如何改变决策链。两张图需要配套使用：先界定系统能访问、调用和影响的范围，再逐个关键决策写出 *R/A/E/O*，检查可见批准是否真的对应有效审查和有效权威。

5.5 本章小结

本章覆盖 ‘00:04:29.919–00:05:12.360’。讲者把分析师例子收束为治理工具：安全团队需要的不只是 capability map，还需要 authority map。能力地图说明系统能执行、调用、访问和影响什么；权威地图说明谁推荐、谁批准、谁执行、谁担责。可见批准只能证明动作发生，不能单独证明审查充分。尤其在机器速度压过人类速度时，authority map 必须进入上线评审、红队、审计和变更流程。

6 总结：把批准按钮还原成责任机制

6.1 结尾真正留下的是 decision authority

‘00:05:12–00:05:31’ 主要是 lightning talk 的收尾。讲者提到 survey 和 QR code，这属于会议互动背景，不应展开成正文内容。这里唯一需要保留的实质性收束是 decision authority：智能体化 AI 流程的关键问题，仍然是每个决策中谁拥有事实决定力，谁能证明判断发生过，谁最终承担责任。

这也解释了本讲题目 “When Humans Stop Thinking” 的尖锐之处。它指向流程设计对人的判断空间的持续压缩。工具越可靠，建议越顺滑，审批队列越快，人类越容易从“判断者”退化成“放行节点”。真正的治理任务，是把批准按钮重新接回证据、复核、暂停和责任机制。

最终收束

本讲的核心避开泛泛反 AI 立场，也避开把所有风险归因于模型错误。它要求组织证明一件更具体的事：每个高影响 AI 决策都能回答 *R/A/E/O* 四问，并能证明 visible approval 对应

meaningful review 和 meaningful authority。

6.2 把全篇压缩成一条审计链

整场短讲可以压缩为一条机制链：

tool → trusted tool → decision authority → fast human approval → accountability blur

第一步，AI 作为工具进入工作流，帮助人类更快获得候选答案。第二步，工具因为有用和总体正确变成 trusted tool。第三步，信任降低复核强度，模型输出开始获得事实决策权威。第四步，人类批准仍可见，却可能在队列压力和默认操作中变成快速放行。第五步，推荐、批准、执行、担责之间的证据链变薄，组织进入责任边界模糊。

一个直观类比

这像驾驶员长期使用导航。早期他会看路牌、看路况、理解路线；导航多次正确后，他开始只听语音提示转弯。方向盘还在手上，动作仍由他完成，可是路线判断已经越来越多地交给导航。agentic AI 流程里的批准按钮，也可能出现同样的权威迁移。

6.3 落到上线、红队和审计

对安全团队来说，本讲最实用的产物是一组流程要求：

- 上线前：为高影响决策写出 authority map，明确 $R/A/E/O$ ，并检查 $O(d)$ 是否落到命名主体。
- 红队时：测试提示注入、数据污染和越权调用之外，还要测试模型建议如何影响人的复核强度。
- 审计时：检查 approve 事件之外的证据链，包括建议依据、批准者可见信息、审查耗时、拒绝路径和执行前中止点。
- 变更时：当模型版本、默认阈值、队列排序或审批 UI 改变时，重新评估 authority map，因为这些细节都会改变事实权威。

这里有一个容易被忽略的风险：组织图上的责任人和流程里的事实权威可能分离。制度上，某个团队仍是 owner；操作上，模型建议、默认按钮和自动执行已经决定大多数结果。若这两层长期分离，事故发生后组织会发现自己拥有很多日志，却缺少能解释判断过程的证据。

未知风险：UI 和队列也是权威机制

很多团队会把 authority map 理解成权限表，忽略 UI 默认值、队列排序、告警聚合、批量批准和 SLA 指标。这些设计会改变人类复核的实际行为。谁的建议排在第一位、哪个按钮最顺手、是否支持延迟执行，都会影响 decision authority 的真实分布。

6.4 本章小结

最终总结覆盖 ‘00:05:12.720–00:05:31.760’，过滤掉 survey 和 QR code 推广内容，只保留 decision authority 这一条实质收束。全篇要带走的是一套责任机制：每个 agentic AI 决策都应写出 $M(d) = (R, A, E, O)$ ，每次可见批准都应能证明有效审查，每个执行动作都应能追到清楚的责任归属。否则，人类看起来仍在流程中，决策权威和责任证据却可能已经悄然转移。